

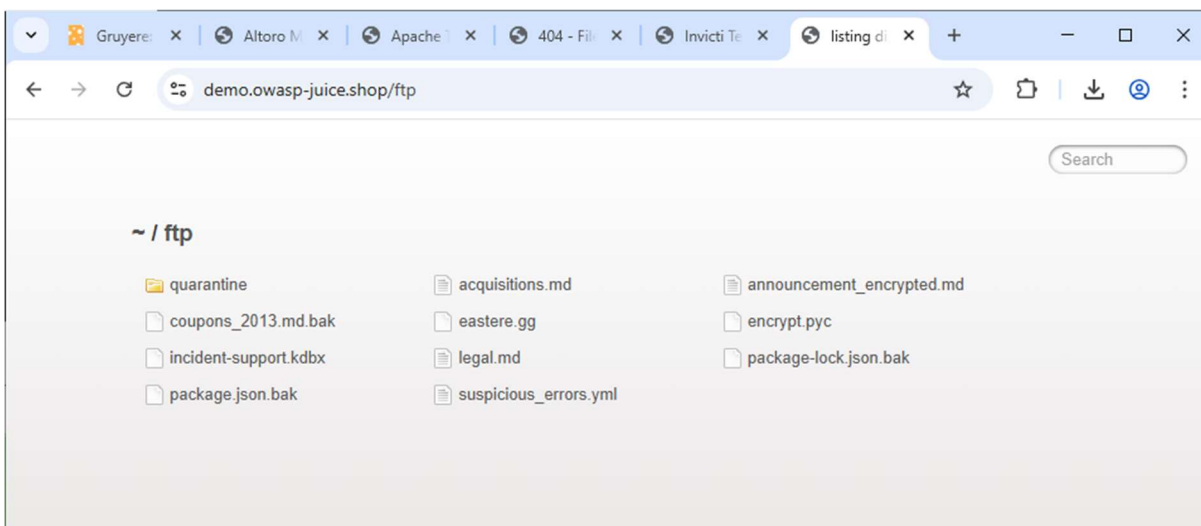
Struktura Raportu: Blok 3 – Web Security i bazy danych

1. Metryka audytu

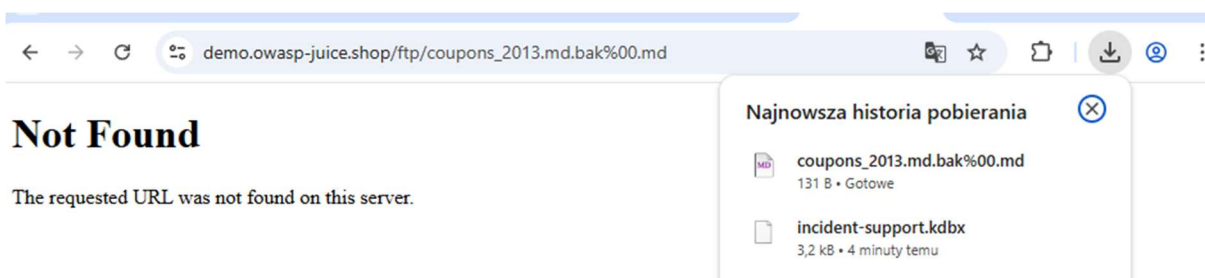
- **Obiekt testów:** OWASP Juice Shop (v12.x / Demo Instance) oraz platformy testowe (Hack-Yourself-First, Altoro Mutual).
- **Audytor:** Patryk Piorunowicz
- **Data testów:** 20.05.2026
- **Zakres:** Analiza podatności na ataki Broken Access Control, SQL Injection oraz Cross Site Scripting.

2. Część 1: Broken Access Control (niewłaściwa kontrola dostępu)

- **Opis podatności:** Próba dostępu do niepublicznych zasobów serwera poprzez bezpośrednie wpisywanie ścieżek w adresie URL (np. /ftp, /admin).
- **Znalezione pliki:** Z katalogu /ftp udało się pobrać pliki:
 1. coupons_2013.md.bak
 2. incident-support.kdbx
- **Zrzuty ekranu (screeny):**
 - *Widok wylistowanej zawartości folderu FTP:*



- *Dowód pobrania zablokowanych plików :*

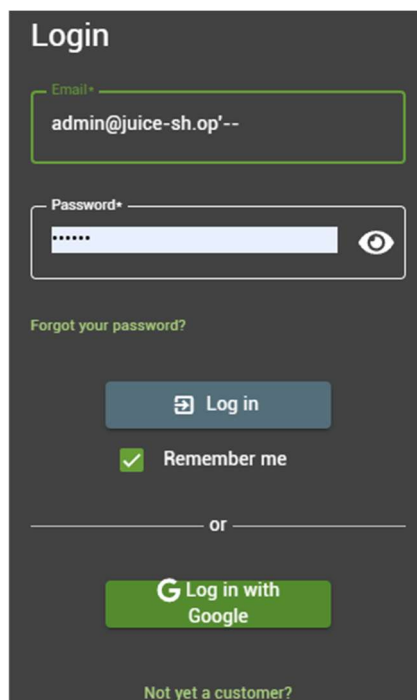


- **Analiza ryzyka (odpowiedzi na pytania):**

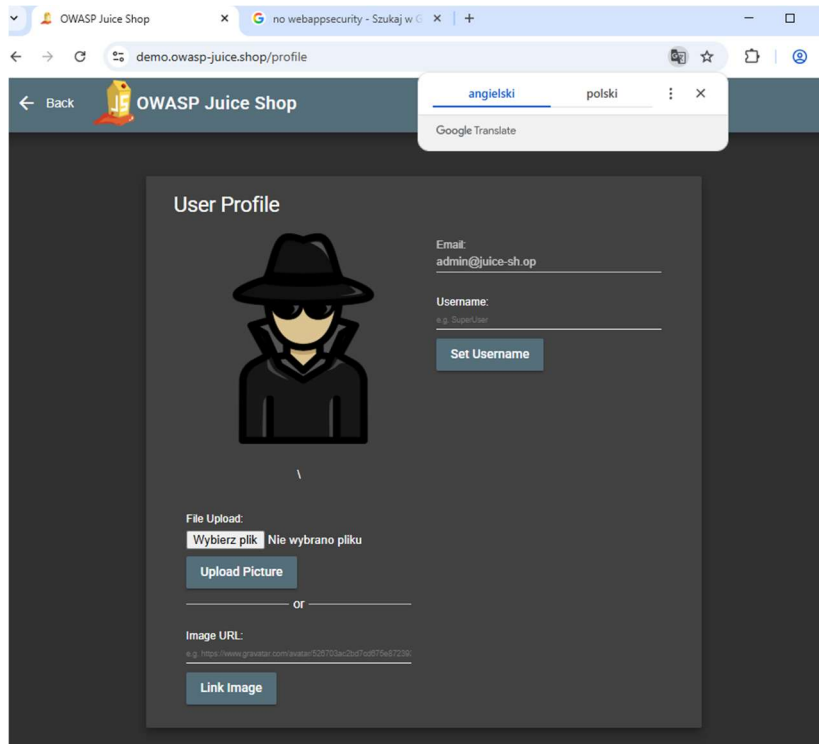
- **Dlaczego pliki .bak i .json to zagrożenie?** Mogą zawierać zapomniane przez programistów hasła, klucze API, logi oraz kody źródłowe, co ułatwia hakerowi atak na system.
- **Który plik z folderu /ftp jest najgroźniejszy?** Plik incident-support.kdbx (baza haseł KeePass). Jego pobranie i złamanie daje hakerowi dostęp do wszystkich haseł w firmie.
- **Dlaczego IDOR jest groźny dla e-zdrowia?** Pozwala użytkownikowi zmienić numer ID w adresie (np. z id=25 na id=26) i natychmiast zobaczyć poufne dane medyczne i wyniki badań innych pacjentów.
- **Rekomendacja dla IDOR:** Sprawdzanie po stronie serwera, czy aktualnie zalogowany użytkownik ma uprawnienia do wyświetlenia zasobu o konkretnym ID.

3. Część 2: SQL Injection (ominięcie autoryzacji)

- **Cel ataku:** Logowanie na konto administratora bez znajomości hasła.
- **Zastosowany ładunek (Payload):**
- admin@juice-sh.op'--
- **Dowód ataku (screen):**
 - *Wstrzyknięcie ładunku w formularzu logowania :*



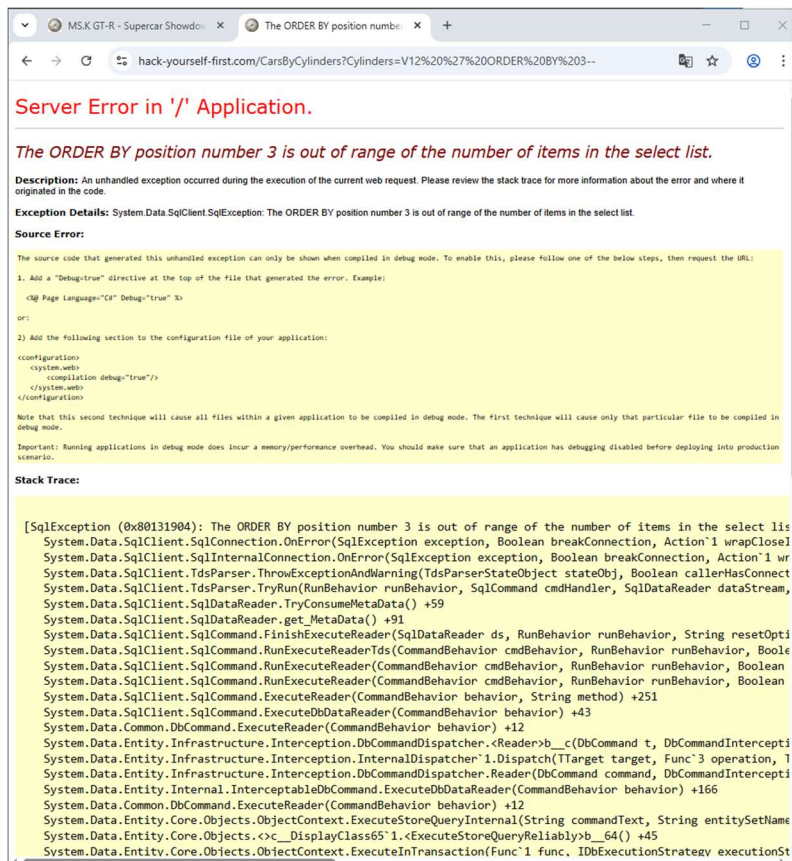
○ *Widok zalogowanego konta administratora :*



- **Wniosek techniczny (odpowiedzi na pytania):**
 - **Co oznacza znak -- w zapytaniu SQL?** Rozpoczyna komentarz jednoliniowy. Nakazuje bazie zignorować resztę zapytania (w tym weryfikację hasła), logując nas wyłącznie przy użyciu e-maila.
 - **Dlaczego SQLi jest groźne dla inżyniera danych?** Pozwala hakerowi na bezpośrednie wydawanie poleceń bazie danych. Haker może kraść, modyfikować lub całkowicie usunąć całą bazę.
 - **Jakie dane mogą wyciec przez ten błąd?** Wszystkie zgromadzone dane: numery PESEL, diagnozy, historie chorób, dokumentacja techniczna oraz dane telemetryczne.
 - **Rekomendacja (Prepared Statements):** Zapytania parametryzowane. Oddzielają one kod SQL od danych użytkownika, dzięki czemu złośliwy wpis hakera jest traktowany wyłącznie jako zwykły tekst, a nie polecenie.

4. Część 3: SQL Injection (ekstrakcja danych - UNION)

- **Cel ataku:** Pobranie wersji bazy danych oraz listy tabel.
- **Kroki techniczne:**
 1. **Liczba kolumn w zapytaniu:** Wyznaczono liczbę kolumn za pomocą klauzuli ORDER BY. Błąd przy próbie odwołania do kolumny 3 wskazał, że oryginalna tabela ma dokładnie **2** kolumny.



2. Zastosowany Payload UNION:

3. V12' UNION SELECT '1',@@version--

(Do odczytania nazw tabel użyto payloadu: V12' UNION SELECT '1',table_name FROM information_schema.tables--)

- **Dane wyjściowe:** Odczytana wersja bazy danych: Microsoft SQL Azure (RTM) - 12.0.2000.8

MS.K GT-R - Supercar Showdown x Supercars with a V12' UNION SELECT x +

hack-yourself-first.com/CarsByCylinders?Cylinders=V12%27%20UNION%20SELECT%20%271%2...
angielski polski
Google Translate

Supercar Showdown

Supercars with a V12' UNION SELECT '1',@@version-- engine layout



Huayra
[View](#)



LaFerrari
[View](#)



Microsoft SQL Azure (RTM) - 12.0.2000.8
Mar 13 2026 08:25:28
Copyright (C) 2025 Microsoft Corporation
[View](#)



One-77
[View](#)

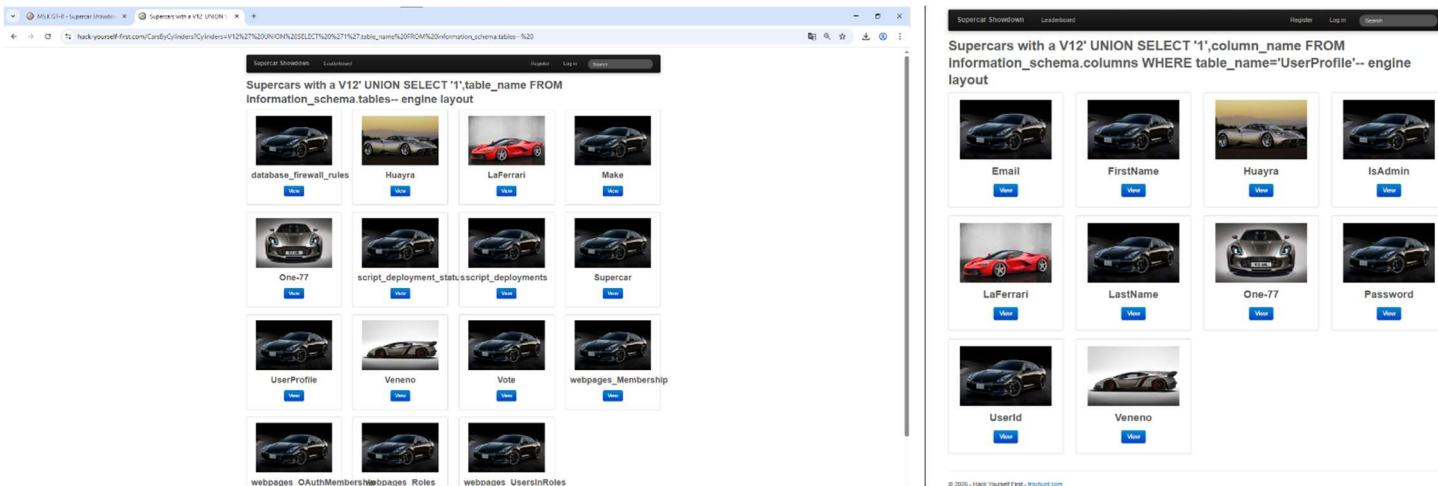


Veneno
[View](#)

© 2026 - Hack Yourself First - troyhunt.com

- **Wnioski (odpowiedzi na pytania):**

○ **Zagrożenie odczytania struktury bazy:** Ujawnia nazwy tabel i kolumn

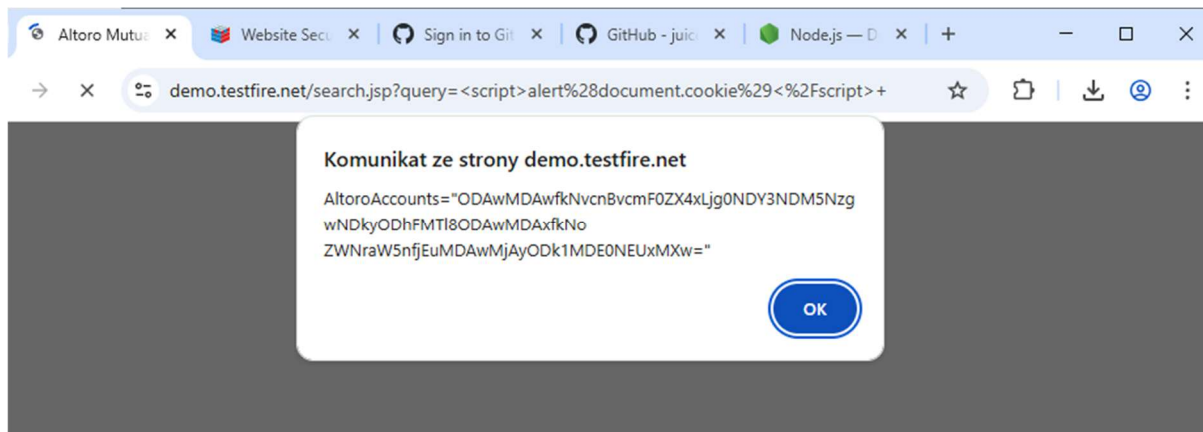


Haker dowiadyuje się dokładnie, w których tabelach leżą hasła czy dane osobowe, i może precyzyjnie je pobrać.

- **Skutki wyciągnięcia diagnoz i PESEL przez UNION SELECT:** Całkowite złamanie prywatności pacjentów i przepisów RODO, co rodzi natychmiastowe ryzyko szantażu oraz wielomilionowych kar dla placówki.
- **Rola zasady minimalnych uprawnień (Least Privilege):** Jeśli konto bazy danych, z którego korzysta aplikacja, ma uprawnienia tylko do tabeli produktów, baza zablokuje każdą próbę odczytania haseł czy danych personalnych za pomocą UNION.

5. Część 4: Cross-Site Scripting (XSS)

- **Typ ataku:** Odzwierciedlony oraz Trwały
- **Zastosowany Payload:**
- `<script>alert(document.cookie)</script>`
- **Dowód ataku (Screen):**
 - *Alert XSS z ciasteczkami sesyjnymi:*



- *DOM XSS podmieniający zawartość strony:*



- **Analiza (odpowiedzi na pytania):**

- **XSS przeciwko lekarzowi i technikowi SCADA:**
 - **Lekarz:** Haker kradnie ciasteczko sesyjne lekarza i przejmuje jego konto. Może wtedy zdalnie zmienić wyniki badań lub śmiertelnie zafatshować dawkowanie leków pacjentom.
 - **Technik SCADA:** Haker podmienia interfejs graficzny w przeglądarce technika i wyświetla fałszywy komunikat o awarii, prowokując go do podjęcia błędnych i niebezpiecznych działań fizycznych na urządzeniach.
- **Dlaczego XSS jest groźny dla systemów CMS?** Przejęcie sesji redaktora pozwala na masowe publikowanie fake newsów oraz wstrzykiwanie złośliwych skryptów, które zainfekują komputery wszystkich czytelników portalu.
- **Jak działa Output Encoding (Kodowanie wyjścia)?** Zamienia znaki specjalne (np. < na <). Przeglądarka wyświetla te znaki jako zwykły bezpieczny tekst na ekranie, zamiast interpretować je jako kod JavaScript do uruchomienia.

6. Podsumowanie i rekomendacje (Remediation)

Jako audytor zalecam bezzwłoczne wdrożenie następujących zabezpieczeń:

1. **Dla SQLi:** Bezwzględne stosowanie zapytań parametryzowanych (*Prepared Statements*).
2. **Dla XSS:** Wdrożenie globalnego kodowania danych wyjściowych (*Output Encoding*) i polityki Content Security Policy (CSP).

3. **Dla Access Control:** Zablokowanie dostępu do folderów systemowych (wyłączenie Directory Listing), usunięcie plików backupów z serwera produkcyjnego oraz sprawdzanie uprawnień użytkownika po stronie serwera przy każdym zapytaniu.

Wniosek końcowy: Podsumowując, nasze testy pokazały, że ta aplikacja ma ogromne dziury w zabezpieczeniach (wycieki plików, podatność na włamania do bazy danych i złośliwe skrypty). W obecnym stanie absolutnie nie wolno jej używać w normalnej pracy ani zapisywać w niej żadnych ważnych informacji takich jak numery PESEL, historia chorób pacjentów czy odciski palców.